

**UNIVERSIDADE ESTADUAL DE CIÊNCIAS DA SAÚDE DE ALAGOAS  
PROGRAMA DE EDUCAÇÃO PELO TRABALHO PARA A SAÚDE — PET-SAÚDE  
CENTRO DE DIAGNÓSTICO E IMAGEM PROFESSOR ALBERTO CARDOSO —  
CEDIM**

**JOSÉ ALAN DE AQUINO SANTOS**

**AVALIAÇÃO TÉCNICA DO SISTEMA DE ANAMNESES CEDIM:  
CAMPOS, SEGURANÇA E PLANO DE TRABALHO**

**MACEIÓ  
2026**

JOSÉ ALAN DE AQUINO SANTOS

**AVALIAÇÃO TÉCNICA DO SISTEMA DE ANAMNESES CEDIM:  
CAMPOS, SEGURANÇA E PLANO DE TRABALHO**

Relatório técnico apresentado à equipe de desenvolvimento e à orientação do Programa de Educação pelo Trabalho para a Saúde (PET-Saúde) da Universidade Estadual de Ciências da Saúde de Alagoas, como registro da verificação realizada na plataforma de anamneses do CEDIM, das correções já aplicadas e da distribuição de tarefas da equipe.

Versão de 25 de setembro de 2026.

**MACEIÓ  
2026**

## RESUMO

Este relatório registra a verificação técnica da plataforma de anamneses mamárias do CEDIM, desenvolvida no âmbito do PET-Saúde da UNCISAL. A verificação foi conduzida com a aplicação em execução, de modo que cada defeito relatado corresponde a um comportamento observado, e não a uma suspeita levantada por leitura de código. O documento cumpre três objetivos. Primeiro, descreve os campos que compõem a anamnese, o que cada um representa e em que formato é gravado, suprimindo uma lacuna de documentação do projeto. Segundo, apresenta os vinte e nove pontos de melhoria identificados, dos quais o mais grave anula por completo o controle de acesso: o componente que protege as rotas verifica apenas a presença do identificador de sessão, sem conferir sua autenticidade, de forma que qualquer pessoa lê e grava prontuários sem credencial válida. Terceiro, propõe uma distribuição de tarefas entre os três desenvolvedores e a orientação do projeto, separando o que depende de conhecimento técnico do que depende de conhecimento clínico. Esta versão registra ainda as correções aplicadas até 25 de setembro de 2026: a primeira etapa do plano foi concluída, e o controle de acesso passou a validar a assinatura da sessão, de modo que a falha descrita acima não se reproduz mais. Permanecem pendentes os pontos de desempenho, de modelo de dados e de definição clínica.

**Palavras-chave:** Registro eletrônico em saúde. Segurança da informação. Controle de acesso. Anamnese mamária. PET-Saúde.

## SUMÁRIO

|                                                            |           |
|------------------------------------------------------------|-----------|
| <b>1 INTRODUÇÃO .....</b>                                  | <b>5</b>  |
| <b>2 METODOLOGIA .....</b>                                 | <b>6</b>  |
| <b>3 O SISTEMA AVALIADO .....</b>                          | <b>7</b>  |
| <b>4 OS CAMPOS DA ANAMNESE .....</b>                       | <b>8</b>  |
| 4.1 Identificação da paciente .....                        | 8         |
| 4.2 Histórico mamário .....                                | 9         |
| 4.3 História reprodutiva .....                             | 9         |
| 4.4 História familiar e hábitos .....                      | 10        |
| 4.5 Exame físico .....                                     | 10        |
| 4.6 Pontos a confirmar com a orientação .....              | 11        |
| <b>5 RESULTADOS DA VERIFICAÇÃO .....</b>                   | <b>12</b> |
| 5.1 Segurança .....                                        | 12        |
| 5.2 Defeitos funcionais .....                              | 13        |
| 5.3 Desempenho e modelo de dados .....                     | 13        |
| 5.4 Documentação e qualidade .....                         | 13        |
| <b>6 CORREÇÕES JÁ APLICADAS .....</b>                      | <b>15</b> |
| 6.1 O controle de acesso passou a funcionar .....          | 15        |
| 6.2 Demais correções .....                                 | 16        |
| <b>7 PLANO DE AÇÃO .....</b>                               | <b>17</b> |
| <b>8 DISTRIBUIÇÃO DE TAREFAS .....</b>                     | <b>18</b> |
| 8.1 José Alan — Segurança e autenticação .....             | 18        |
| 8.2 Alan da Silva — Dados e desempenho .....               | 18        |
| 8.3 Lucas Pedroza — Interface e qualidade .....            | 19        |
| 8.4 Professor Gustavo Figueiredo — Definição clínica ..... | 20        |
| <b>9 CONSIDERAÇÕES FINAIS .....</b>                        | <b>21</b> |
| <b>REFERÊNCIAS .....</b>                                   | <b>22</b> |

## 1 INTRODUÇÃO

O Sistema de Anamneses CEDIM é uma plataforma web que substitui o preenchimento em papel da anamnese mamária: a estudante ou profissional preenche um formulário clínico na tela, marca achados sobre um desenho esquemático das mamas e grava o registro, que fica disponível para consulta, exportação em planilha e agregação em gráficos.

Um sistema assim guarda aquilo que a Lei Geral de Proteção de Dados Pessoais define como *dado pessoal sensível* — informação referente à saúde de pessoa identificada (BRASIL, 2018, art. 5º, II) —, submetido a regime de proteção mais estrito que o dos dados comuns. A qualidade técnica da plataforma deixa, portanto, de ser conveniência e passa a ser questão de conformidade legal.

Este relatório registra a verificação realizada em 23 de setembro de 2026. Não pretende criticar o trabalho feito, que resolve o problema proposto e está em funcionamento, mas produzir um retrato do estado atual, documentar os campos da anamnese e propor uma divisão de tarefas para a equipe. Os conceitos técnicos são explicados à medida que aparecem, pois o documento se dirige também à orientação do projeto.

## 2 METODOLOGIA

A verificação foi conduzida com a aplicação em execução, e não apenas por leitura do código-fonte. A distinção importa: ler o código levanta suspeitas, mas só a execução confirma que o problema acontece. Cada defeito da seção 5 foi reproduzido ao menos uma vez.

O ambiente foi montado de forma isolada, seguindo o procedimento de instalação da própria documentação do projeto — o que permitiu verificar, de passagem, se essas instruções ainda funcionam. Com o sistema no ar, foram exercitados o fluxo de autenticação, as seis rotas de programação (com e sem credenciais), a gravação de registros completos, vazios e repetidos, a remoção de registros existentes e inexistentes, e a medição do volume de dados trafegado. A descrição dos campos da seção 4 foi extraída do código do formulário, única fonte existente sobre o assunto até este trabalho.

### 3 O SISTEMA AVALIADO

A plataforma usa Next.js, estrutura que reúne num mesmo projeto as telas e a programação de servidor. O armazenamento fica em banco MySQL, acessado pelo Prisma. São quatro telas: formulário de anamnese, listagem de registros, painel de métricas e tela de acesso. Não há autocadastro; um usuário administrador é criado na instalação.

Um ponto da arquitetura explica vários achados adiante. Todo o conteúdo clínico é gravado em uma única coluna do banco, no formato JSON — um texto estruturado. A tabela possui seis colunas, e nenhuma corresponde a um campo clínico: `id`, `data` (o bloco JSON com tudo), três colunas de imagem e a data de gravação.

A consequência é que o banco não sabe o que guarda. Para ele, a anamnese inteira é um texto só. Não há como exigir que toda anamnese tenha nome de paciente, nem como localizar uma paciente sem percorrer todos os registros.

## 4 OS CAMPOS DA ANAMNESE

Esta seção descreve os campos do formulário: o que cada um representa e em que formato é gravado. Até este trabalho, essa informação existia apenas no código-fonte, o que obrigava cada nova integrante da equipe a redescobri-la por leitura.

Os quadros indicam o nome técnico do campo — o mesmo que aparece nas planilhas exportadas —, o rótulo exibido na tela e o formato gravado. As linhas destacadas em cinza indicam campos cuja definição clínica precisa ser confirmada pela orientação, conforme a seção 4.6.

### 4.1 Identificação da paciente

**Quadro 1** — Campos de identificação

| Campo técnico      | Rótulo na tela     | Formato e observações                                                                            |
|--------------------|--------------------|--------------------------------------------------------------------------------------------------|
| nome               | Nome               | Texto livre                                                                                      |
| telefone           | Telefone           | Texto livre, sem máscara nem validação                                                           |
| cidade             | Cidade             | Texto livre — sem lista fixa, o que gera grafias divergentes nos gráficos                        |
| dataNascimento     | Data de Nascimento | Data. Base do cálculo de idade no painel de métricas                                             |
| motivo             | Motivo do Exame    | Texto livre — alimenta o gráfico de casos clínicos                                               |
| exame              | Data do Exame      | Data informada pela usuária                                                                      |
| idExamesAnteriores | ID do Paciente     | Texto livre. O nome técnico sugere exames anteriores, mas o rótulo diz identificação da paciente |

Fonte: elaborado pelo autor a partir de `components/anamnesis-form.jsx`.

## 4.2 Histórico mamário

Quadro 2 — Campos de histórico mamário

| Campo técnico       | Rótulo na tela                        | Formato e observações                                       |
|---------------------|---------------------------------------|-------------------------------------------------------------|
| aproveitarExames    | Realizou exames anteriores            | Sim ou não                                                  |
| jaFezMamo           | Já fez mamografia ou ultrassonografia | Sim ou não                                                  |
| sintomas            | Sintomas apresentados                 | Três marcações independentes: dor, massa e secreção         |
| corSecrecao         | Cor da secreção                       | Texto livre                                                 |
| especifiqueSintomas | Secreção sai espontânea?              | Texto livre. Nome técnico genérico para pergunta específica |
| jaFezCirurgia       | Já fez cirurgia das mamas             | Quatro marcações: mamoplastia, prótese, nódulos e câncer    |
| tempoCirurgia       | Tempo de cada cirurgia                | Texto livre, um por tipo de cirurgia                        |
| cancer              | Diagnóstico de câncer pessoal         | Sim ou não                                                  |
| especificarCancer   | Localização do câncer                 | Texto livre                                                 |
| historiaDoenca      | História da doença mamária            | Campo de texto longo — o único do formulário                |

Fonte: elaborado pelo autor.

## 4.3 História reprodutiva

Quadro 3 — Campos de história reprodutiva

| Campo técnico       | Rótulo na tela                   | Formato e observações                                   |
|---------------------|----------------------------------|---------------------------------------------------------|
| numeroGestacoes     | Número de gestações              | Número, gravado como texto                              |
| numeroPartos        | Número de partos                 | Número, gravado como texto                              |
| numeroAbortos       | Número de abortos                | Número, gravado como texto                              |
| historiaReprodutiva | Amamentou · Menopausa · Hormônio | Três marcações independentes                            |
| dum                 | DUM (data da última menstruação) | Data. <b>Só aparece quando "Amamentou" está marcado</b> |
| tempoMenopausa      | Tempo de menopausa               | Texto livre; exibido apenas se "Menopausa" marcado      |
| tempoHormonio       | Tempo com hormônio               | Texto livre; exibido apenas se "Hormônio" marcado       |

Fonte: elaborado pelo autor.

## 4.4 História familiar e hábitos

**Quadro 4** — Campos de história familiar e hábitos

| Campo técnico    | Rótulo na tela                                                     | Formato e observações                                                                                                                    |
|------------------|--------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------|
| alguemComCancer  | Alguém com câncer de mama na família                               | Sim ou não                                                                                                                               |
| parentescoCancer | Parentesco                                                         | Texto livre; exibido apenas se a resposta for "sim". Não distingue grau de parentesco nem idade ao diagnóstico                           |
| habitos          | Fuma · Bebe · Exercício físico · Alimentação saudável · Auto-exame | Cinco marcações independentes. Aparecem duas vezes no relatório impresso: como "Hábitos" e como "Fatores de risco" — são os mesmos dados |

Fonte: elaborado pelo autor.

## 4.5 Exame físico

A seção de exame físico combina dois desenhos esquemáticos das mamas, sobre os quais a usuária marca achados com o mouse ou com o dedo, e campos de seleção associados a cada desenho.

**Quadro 5** — Campos de exame físico

| Campo técnico                | Rótulo na tela      | Formato e observações                                                                                      |
|------------------------------|---------------------|------------------------------------------------------------------------------------------------------------|
| imagemMamaA                  | Canvas A            | Desenho com as marcações, gravado como imagem. A tela não informa o que distingue este desenho do seguinte |
| exameFisicoA.massa           | Massa na mama?      | Sim ou não                                                                                                 |
| indicada                     | Indicada            | Paciente, médico ou técnico. O rótulo não explicita o que está sendo indicado                              |
| imagemMamaB                  | Canvas B            | Segundo desenho, mesmo formato do anterior                                                                 |
| exameFisicoB.alteracaoPele   | Alteração na pele?  | Coloração vermelha, verruga ou sinais, outros                                                              |
| exameFisicoB.alteracaoMamilo | Alteração do mamilo | Retração, espessamento, erosão, coloração vermelha, outros                                                 |

Fonte: elaborado pelo autor.

Quando a opção escolhida é "outros", abre-se um campo de texto para descrição livre. As marcações feitas sobre os desenhos são gravadas apenas como imagem: não podem ser reabertas nem ajustadas depois, e seu conteúdo não é pesquisável.

#### 4.6 Pontos a confirmar com a orientação

Os itens a seguir não podem ser resolvidos por análise técnica, pois dependem do protocolo clínico adotado pelo serviço. Constituem a pauta sugerida para a orientação do projeto.

**Quadro 6** — Pontos que dependem de definição clínica

| Nº | Questão                                                           | Situação atual                                                                            |
|----|-------------------------------------------------------------------|-------------------------------------------------------------------------------------------|
| 1  | A DUM deve mesmo aparecer apenas quando "Amamentou" está marcado? | É o comportamento atual; a associação não é evidente                                      |
| 2  | O que distingue clinicamente o Canvas A do Canvas B?              | A tela não informa; os dois são idênticos em função                                       |
| 3  | O campo "Indicada" se refere a quem indicou o exame?              | Aceita paciente, médico ou técnico, sem explicação na tela                                |
| 4  | Quais campos devem ser obrigatórios?                              | Nenhum é. O sistema grava anamnese inteiramente vazia                                     |
| 5  | O vocabulário de alterações de pele e mamilo está adequado?       | Lista fixa; "coloração vermelha" aparece nos dois campos com grafias internas divergentes |
| 6  | O parentesco deve registrar grau e idade ao diagnóstico?          | Hoje é texto livre, o que impede estratificação de risco familiar                         |
| 7  | "Motivo do exame" e "Cidade" devem ter lista fixa de opções?      | São texto livre; grafias divergentes fragmentam os gráficos                               |

Fonte: elaborado pelo autor.

## 5 RESULTADOS DA VERIFICAÇÃO

Foram identificados vinte e nove pontos de melhoria: quatro de segurança, sete de defeitos funcionais, quatro de desempenho e modelo de dados, sete de documentação e sete de qualidade de código. Esta seção detalha os mais relevantes.

### 5.1 Segurança

Quando alguém acerta usuário e senha, o servidor emite um *token*: um texto que funciona como crachá digital e fica guardado no navegador. O token é assinado criptograficamente, de modo que qualquer alteração em seu conteúdo invalida a assinatura e denuncia a falsificação.

O sistema emite o crachá corretamente, mas **nunca confere a assinatura**. O componente que protege as rotas verifica apenas se existe algum crachá, sem olhar o que está escrito nele, e as rotas que leem e gravam anamneses não refazem essa verificação. Apresentando-se um crachá de conteúdo arbitrário, sem nenhuma credencial:

```
Cookie: token=isso_nao_e_um_jwt
GET /api/anamneses → 200 (lista todas as anamneses)
POST /api/save-anamnese → 200 (gravou um registro no banco)
```

A senha protege apenas a formalidade de obter um crachá; não protege os dados. A falha corresponde ao primeiro item da classificação da OWASP (2021), *Broken Access Control*, a categoria mais frequente em aplicações web. A correção exige validar a assinatura no componente de proteção e repetir a validação dentro de cada rota, pois esse componente não constitui, sozinho, uma fronteira de segurança.

Há outros três pontos. Uma rota remanescente de versão anterior permite apagar qualquer arquivo do servidor, por não verificar o identificador recebido — confirmado apagando-se um arquivo criado fora do projeto; como é código sem uso, deve ser removida. As mensagens de erro devolvem ao navegador o caminho absoluto das pastas do servidor e sua estrutura interna. E a credencial do usuário administrador está publicada na documentação do repositório.

## 5.2 Defeitos funcionais

**Quadro 7** — Defeitos que afetam o uso diário

| Defeito                                                     | Efeito observado                                          |
|-------------------------------------------------------------|-----------------------------------------------------------|
| Tela de anamnese completa busca os dados no lugar errado    | Exibe sempre "Registro não encontrado"                    |
| Ausência total de validação                                 | Grava anamnese sem nome de paciente                       |
| Resumo e download individual sem acionamento                | Não há como ver a anamnese completa na tela               |
| Campo "Sexo" cobrado pelo painel, inexistente no formulário | Coluna sempre vazia na planilha exportada                 |
| Não há edição de anamnese                                   | Corrigir um erro de digitação exige apagar e refazer tudo |
| Marcações dos desenhos não podem ser reabertas              | Achados ficam congelados na imagem                        |
| Códigos de erro incorretos                                  | Registro inexistente responde como falha do servidor      |

Fonte: elaborado pelo autor.

## 5.3 Desempenho e modelo de dados

A tela de listagem exibe apenas nome, data e cidade, mas a rota que a alimenta devolve todos os registros com todos os campos, incluindo as três imagens de cada um. Não há paginação nem seleção de campos. A medição, com um registro contendo as três imagens, resultou em **781 KB armazenados e 800 KB trafegados**. Com 500 anamneses — volume modesto para um serviço de diagnóstico — cada abertura da tela transferiria cerca de 400 MB, e o painel de métricas repetiria o esforço.

A causa está no modelo descrito na seção 3: como nenhum campo clínico é coluna, não há como pedir apenas o nome e a data. Soma-se a isso que a imagem do relatório reproduz um conteúdo já gravado integralmente no bloco JSON — o mesmo dado ocupa espaço duas vezes, e a versão em imagem não pode ser corrigida nem pesquisada. Registre-se, ainda, que o sistema não guarda quem criou ou apagou cada anamnese.

## 5.4 Documentação e qualidade

A documentação apresentava um problema de natureza distinta. O arquivo de apresentação do projeto declarava:

Sistema Fechado: Todo o acesso (rotas de registros, formulários e métricas) é protegido por Middleware. É necessário estar logado.

A afirmação não corresponde ao comportamento do sistema. O problema não é o erro em si, mas seu efeito: quem lesse a frase concluiria que a proteção estava resolvida e não investigaria adiante. A documentação atuava para impedir a descoberta da falha. A lição é generalizável: documentação que afirma garantias de segurança precisa ser verificada com o mesmo rigor aplicado ao código, porque é lida como prova.

Quanto à qualidade do código, o projeto soma 2.944 linhas próprias e 13 comentários — 0,4%. O arquivo central, com o formulário inteiro, tem 1.004 linhas e nenhum comentário. Para uma equipe que se renova a cada ciclo do PET, isso significa reconstruir o entendimento do zero a cada turma. Permanecem ainda uma tela órfã, uma função de sessenta linhas nunca chamada, arquivos duplicados e uma pasta de 77 MB de compilação incluída no repositório por engano.

## 6 CORREÇÕES JÁ APLICADAS

Entre a verificação, em 23 de setembro, e a redação desta versão do relatório, parte dos pontos levantados já foi corrigida e colocada em produção. Esta seção registra o que mudou, para que a leitura das seções anteriores não induza a equipe a trabalhar sobre um problema resolvido.

**Quadro 8** — Situação dos pontos em 25/09/2026

| Item                                                                | Ponto levantado                             | Situação                        | Responsável               |
|---------------------------------------------------------------------|---------------------------------------------|---------------------------------|---------------------------|
| A1                                                                  | Bypass total de autenticação                | <b>Resolvido</b>                | José Alan                 |
| A2                                                                  | Remoção arbitrária de arquivos do servidor  | <b>Resolvido</b>                | José Alan                 |
| A3                                                                  | Exposição de detalhes internos em erros     | <b>Resolvido</b>                | José Alan                 |
| A4                                                                  | Credenciais de teste em repositório público | Pendente                        | José Alan                 |
| B2                                                                  | Ausência de validação                       | Servidor feito; falta o cliente | José Alan / Lucas Pedroza |
| B3                                                                  | Códigos de erro incorretos                  | <b>Resolvido</b>                | José Alan                 |
| Os demais vinte e três pontos permanecem como descritos na seção 5. |                                             |                                 |                           |

Fonte: elaborado pelo autor.

### 6.1 O controle de acesso passou a funcionar

A verificação da sessão foi centralizada em um único ponto do código e passou a conferir a assinatura do token, e não apenas a sua presença. A conferência acontece em **duas camadas**: no componente que protege as rotas e, de novo, dentro de cada rota que lê ou grava anamneses — justamente porque, como observado na seção 5.1, o primeiro não constitui fronteira de segurança suficiente sozinho.

Um detalhe técnico condicionou a escolha da ferramenta. O componente de proteção de rotas do Next.js roda em um ambiente de execução restrito, o *Edge Runtime*, onde as funções criptográficas do Node não existem — a biblioteca usada até então para assinar os tokens simplesmente não funcionaria ali. Adotou-se em seu lugar uma biblioteca baseada nas funções criptográficas padronizadas dos navegadores, que serve aos dois ambientes, de modo que a proteção de rotas e as rotas de API compartilham exatamente a mesma verificação, sem duplicação de lógica.

A correção foi verificada com um token **bem formado**, de estrutura e conteúdo válidos, assinado com uma chave diferente da do servidor. Esse é o teste que distingue validação de assinatura de simples recusa de texto malformatado:

**Quadro 9** — Comportamento antes e depois, em produção

| Requisição                                          | Antes         | Depois                   |
|-----------------------------------------------------|---------------|--------------------------|
| Cookie arbitrário → listar anamneses                | 200 (listava) | <b>401</b>               |
| Cookie arbitrário → gravar anamnese                 | 200 (gravava) | <b>401</b>               |
| Token assinado com chave errada → listar            | 200           | <b>401</b>               |
| Token assinado com chave errada → tela de registros | 200           | <b>307</b> para o acesso |
| Sem credencial alguma                               | 307           | <b>401</b>               |

Fonte: elaborado pelo autor, a partir de testes contra o ambiente publicado.

Houve ainda uma mudança de comportamento deliberada: as rotas de API passaram a responder **401** em vez de redirecionar para a tela de acesso. O redirecionamento fazia com que as telas recebessem uma página HTML onde esperavam dados, e falhassem na leitura da resposta.

## 6.2 Demais correções

A rota que permitia apagar arquivos do servidor (item A2) foi **removida**, e não apenas corrigida: por ser resquício sem uso, sanitizar o caminho manteria viva uma superfície de ataque desnecessária.

As mensagens de erro deixaram de carregar o detalhe técnico da falha (A3), que expunha o caminho absoluto das pastas do servidor. O erro completo continua registrado internamente, onde é útil para diagnóstico sem ficar visível a terceiros.

Os códigos de resposta foram corrigidos (B3): identificador repetido responde **409** e exclusão de registro inexistente responde **404**, em lugar do *erro interno do servidor* que ambos devolviam.

Por fim, o servidor passou a recusar anamnese sem nome de paciente (B2). A lista de campos exigidos está isolada em um único ponto do código, preparada para receber a definição do protocolo. **Ela é provisória e contém apenas o nome**, por ser o mínimo para que uma ficha seja aproveitável — não se presumiu qual é a exigência clínica, que permanece com a orientação (seção 4.6). Falta ainda a validação na própria tela, para que a usuária veja o erro antes de enviar.

O ambiente publicado acompanha automaticamente a versão mais recente do código: cada alteração aceita entra em produção em cerca de dois minutos, sem intervenção manual, com verificação automática de compilação antes e retorno à versão anterior caso a nova não responda.

## 7 PLANO DE AÇÃO

Os vinte e nove pontos não têm a mesma urgência. A ordenação a seguir parte do risco envolvido, e não da facilidade de execução.

**Quadro 10** — Plano de ação por etapas

| Etapa                                                                   | Ações                                                                                                                                                                                                                      | Justificativa                                                            |
|-------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------|
| <b>1ª</b><br>Antes de qualquer dado real<br>— <b>concluída em 25/09</b> | Validar a assinatura do token nas rotas; remover a rota vulnerável; deixar de expor mensagens internas de erro; implantar validação no servidor. <i>Restam</i> : trocar as credenciais publicadas e validar também na tela | Sem estas, o sistema não oferecia proteção alguma aos dados que armazena |
| <b>2ª</b><br>Estrutural                                                 | Restringir os campos devolvidos pela listagem e paginar; promover nome, cidade e datas a colunas próprias; deixar de gravar a imagem do relatório; corrigir a tela de anamnese completa; implementar edição                | Determinam se o sistema suporta o volume de um serviço real              |
| <b>3ª</b><br>Definição clínica                                          | Responder aos sete pontos do Quadro 6; definir campos obrigatórios e listas fixas; registrar autoria dos registros                                                                                                         | Dependem de conhecimento que não está no código                          |
| <b>4ª</b><br>Dívida técnica                                             | Remover a pasta de compilação e o código sem uso; restabelecer a verificação automática de qualidade; comentar o arquivo central                                                                                           | Reduzem o custo de toda alteração futura                                 |

Fonte: elaborado pelo autor.

A recomendação central permanece, agora com uma ressalva: a primeira etapa foi concluída e o controle de acesso funciona, mas **o endereço publicado continua sem autenticação na camada de rede** — decisão consciente, tomada para facilitar a demonstração. Enquanto assim permanecer, a plataforma não deve receber dados de pacientes reais, ainda que o acesso à aplicação já exija credencial válida.

## 8 DISTRIBUIÇÃO DE TAREFAS

A equipe é formada por José Alan, Alan da Silva e Lucas Pedroza, sob orientação do Professor Gustavo Figueiredo. A divisão agrupa as tarefas por afinidade técnica, de modo que cada pessoa trabalhe predominantemente em arquivos distintos e os três avancem em paralelo.

Registre-se uma ressalva sobre essa separação: as rotas de programação que tratam das anamneses são tocadas tanto por José Alan, no controle de acesso, quanto por Alan da Silva, no desempenho das consultas. São arquivos curtos, e alterações simultâneas neles colidem com facilidade. A ordem proposta resolve o problema — o trabalho de José Alan sobre essas rotas já foi concluído, de forma que Alan da Silva e Lucas Pedroza podem agora alterá-las sem conflito.

### 8.1 José Alan — Segurança e autenticação

Responsável pela primeira etapa do plano, que era bloqueante para as demais. **Concluída em 25 de setembro de 2026**, o que liberou o trabalho dos outros dois desenvolvedores.

**Quadro 11** — Tarefas de José Alan

| Tarefa                                                                                                     | Situação                                                                  |
|------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------|
| Validar a assinatura do token no componente de proteção de rotas                                           | <b>Concluída</b>                                                          |
| Repetir a validação dentro de cada rota que lê ou grava anamneses                                          | <b>Concluída</b>                                                          |
| Remover a rota que permitia apagar arquivos do servidor                                                    | <b>Concluída</b>                                                          |
| Parar de devolver o detalhe técnico do erro ao navegador                                                   | <b>Concluída</b>                                                          |
| Corrigir os códigos de resposta de registro repetido e inexistente                                         | <b>Concluída</b>                                                          |
| Validar no servidor os campos definidos como obrigatórios                                                  | Mecanismo pronto; aguarda a definição da orientação                       |
| Substituir as credenciais de teste publicadas no repositório (A4)                                          | Pendente                                                                  |
| Remover a exclusão de anamnese e sustentar a guarda permanente com data de última alteração e autoria (A5) | Pendente — aguarda a edição do Quadro 13; as duas saem na mesma alteração |
| Implantar o escopo de permissões: papel no cadastro, no token e nas rotas (A6)                             | Pendente — princípio definido em 25/09/2026; matriz de papéis a definir   |

Fonte: elaborado pelo autor.

## 8.2 Alan da Silva — Dados e desempenho

Responsável pela segunda etapa, na camada de banco e nas rotas de leitura. **Pode começar imediatamente:** as rotas que também são de sua responsabilidade já receberam as alterações de segurança, de modo que não há mais risco de conflito.

**Quadro 12** — Tarefas de Alan da Silva

| Tarefa                                                                                     | Situação                       |
|--------------------------------------------------------------------------------------------|--------------------------------|
| Excluir as colunas de imagem da listagem e implantar paginação                             | Pendente — maior ganho isolado |
| Promover nome, cidade, data de emissão e data de nascimento a colunas próprias, com índice | Pendente                       |
| Deixar de gravar a imagem do relatório; gerá-la sob demanda                                | Pendente                       |
| Registrar autoria: vincular cada anamnese ao usuário que a criou                           | Pendente                       |
| Remover do repositório a pasta de compilação de 77 MB                                      | Pendente                       |

Fonte: elaborado pelo autor.

## 8.3 Lucas Pedroza — Interface e qualidade

Responsável pelos defeitos visíveis a quem usa o sistema e pela dívida técnica acumulada. **Pode começar imediatamente.**

Uma observação importante: a rota de edição a ser criada precisa chamar a verificação de sessão por conta própria, seguindo o padrão já estabelecido nas demais rotas (seção 6.1). Sem isso, a funcionalidade nasce desprotegida, reintroduzindo o problema que acaba de ser corrigido.

**Quadro 13** — Tarefas de Lucas Pedroza

| Tarefa                                                                         | Situação                                                                                                                                                 |
|--------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------|
| Validar o formulário antes do envio, conforme os campos obrigatórios definidos | Pendente — complementa o que o servidor já recusa                                                                                                        |
| Corrigir a tela de anamnese completa, que busca os dados no lugar errado       | Pendente                                                                                                                                                 |
| Implementar a edição de anamnese já gravada                                    | Pendente e <b>bloqueante</b> — virou o único meio de correção, já que não se pode apagar; exige verificação de sessão e preservação do conteúdo anterior |
| Acionar o resumo e o download individual, hoje sem botão                       | Pendente                                                                                                                                                 |
| Remover a coluna "Sexo" da exportação ou acrescentar o campo ao formulário     | Pendente                                                                                                                                                 |
| Aplicar as listas fixas definidas pela orientação para cidade e motivo         | Aguarda a orientação                                                                                                                                     |
| Remover o código sem uso e comentar o arquivo central por seção clínica        | Pendente                                                                                                                                                 |

Fonte: elaborado pelo autor.

#### 8.4 Professor Gustavo Figueiredo — Definição clínica

Nenhuma das tarefas abaixo pode ser resolvida pela equipe de desenvolvimento, pois dependem do protocolo do serviço e da leitura radiológica, área de formação do orientador. São, ao mesmo tempo, pré-requisito para parte do trabalho dos três desenvolvedores — a coluna à direita indica quem fica à espera de cada definição.

**Quadro 14** — Tarefas do Professor Gustavo Figueiredo

| Tarefa                                                                                                                                                                                                                                                                                                                                                                                                     | Desbloqueia                   |
|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------|
| Responder aos sete pontos do Quadro 6, em especial a condição da DUM e a distinção entre os dois desenhos esquemáticos                                                                                                                                                                                                                                                                                     | Lucas Pedroza                 |
| Definir quais campos são obrigatórios para que a anamnese seja considerada válida                                                                                                                                                                                                                                                                                                                          | José Alan e Lucas Pedroza     |
| Revisar o vocabulário de alterações de pele e mamilo, à luz da terminologia radiológica adotada                                                                                                                                                                                                                                                                                                            | Lucas Pedroza                 |
| Definir se o parentesco deve registrar grau e idade ao diagnóstico, para estratificação de risco                                                                                                                                                                                                                                                                                                           | Alan da Silva e Lucas Pedroza |
| Definir as listas fixas de "motivo do exame" e "cidade"                                                                                                                                                                                                                                                                                                                                                    | Lucas Pedroza                 |
| Validar o significado de cada campo descrito na seção 4, para incorporação à documentação                                                                                                                                                                                                                                                                                                                  | Equipe                        |
| Definir por quanto tempo os registros devem ser conservados e quem pode acessá-los — <i>respondido em 25/09/2026: guarda indefinida, acima do mínimo legal de 20 anos; acesso restrito a profissionais e estudantes da área da saúde autorizados pelo serviço; e nenhum perfil pode apagar anamnese, apenas editá-la. Resta a matriz de papéis: quem autoriza uma conta e o que cada papel pode fazer.</i> | José Alan e Alan da Silva     |

Fonte: elaborado pelo autor.

Sugere-se que a seção 4 deste relatório seja revisada em conjunto com a orientação e, uma vez validada, incorporada à documentação do repositório como dicionário de dados oficial do projeto.

## 9 CONSIDERAÇÕES FINAIS

A plataforma cumpre o que se propôs: digitaliza um processo feito em papel, permite consultar e exportar o que foi registrado e produz indicadores agregados. A compilação de produção funciona, o procedimento de instalação da documentação foi executado com sucesso e as telas respondem como esperado. Não é pouco para um projeto estudantil.

Os problemas relatados situam-se em camada distinta daquela em que o trabalho foi concebido. Não dizem respeito ao que o sistema faz, e sim às condições sob as quais pode operar com segurança e crescer. É uma diferença comum em software que nasce como prova de conceito e é promovido a ferramenta de trabalho sem etapa intermediária de revisão — e é essa etapa que este relatório registra.

Chama-se a atenção, por fim, para o achado da seção 5.4, cujo alcance ultrapassa este projeto. A documentação afirmava que o controle de acesso funcionava, e essa afirmação bastava para encerrar o assunto aos olhos de quem a lesse. Documentação não é observação neutra sobre um sistema: ela orienta o que as pessoas vão ou não verificar. Quando descreve garantias de segurança, precisa ser tratada como afirmação a comprovar, não como descrição a aceitar.

## REFERÊNCIAS

ASSOCIAÇÃO BRASILEIRA DE NORMAS TÉCNICAS. **NBR 6023**: informação e documentação: referências: elaboração. Rio de Janeiro: ABNT, 2018.

ASSOCIAÇÃO BRASILEIRA DE NORMAS TÉCNICAS. **NBR 6024**: informação e documentação: numeração progressiva das seções de um documento: apresentação. Rio de Janeiro: ABNT, 2012.

ASSOCIAÇÃO BRASILEIRA DE NORMAS TÉCNICAS. **NBR 6028**: informação e documentação: resumo, resenha e resenha: apresentação. Rio de Janeiro: ABNT, 2021.

ASSOCIAÇÃO BRASILEIRA DE NORMAS TÉCNICAS. **NBR 14724**: informação e documentação: trabalhos acadêmicos: apresentação. Rio de Janeiro: ABNT, 2011.

BRASIL. **Lei nº 13.709, de 14 de agosto de 2018**. Lei Geral de Proteção de Dados Pessoais (LGPD). Brasília, DF: Presidência da República, 2018.

OPEN WORLDWIDE APPLICATION SECURITY PROJECT. **OWASP Top 10:2021**: the ten most critical web application security risks. [S. l.]: OWASP Foundation, 2021.